• L'ouverture de session interactives locales est gérée par la coordination de plusieurs composants le processus d'ouverture de session (Winlogon) le processus de l'interface utilisateur de l'ouverture de session (LogonUI), les fournisseurs d'informations d'identification, le service de sous système de l'autorité de sécurité local (LSASS) un ou plusieurs packages d'authentification, et soit le gestionnaire de compte de sécurité (SAM) soit Active Directory (AD).

+ Les packages d'authentification dans ce contexte sont des bibliothèques de lien dynamique (DLL) chargées d'effectuer les vérifications d'authentification.

• WinLogon est le seul processus qui intercepte les demandes de connexion provenant du clavier, qui sont envoyées via des messages RPC depuis Win32k.sys. Lors de l'ouverture de session, il lance immédiatement l'application LogonUI pour présenter l'interface utilisateur graphique. Une fois les informations d'identification de l'utilisateur collectées, Winlogon les transmet au services de sous-système de l'autorité de sécurité locale (LSASS) pour authentifier l'utilisateur.

LSASS: est composé de plusieurs modules et régit tout les processus d'authentification. Situé dans %SystemRoot%\System32\Lsass.exe dans le système de fichiers

Base de donnée SAM: Le gestionnaire de compte de sécurité (SAM) est le fichier de base de donnée dans le system d'exploitation Windows qui stocke les informations d'identification des comptes d'utilisateurs. Les mots de passes utilisateurs sont stockés sous forme de hashage dans le registre (généralement LM ou NTLM). La désactivation et l'accès a ce fichier nécessite des privilèges SYSTEM. Il se trouve à l'emplacement %SystemRoot%\System32\config\SAM

+ Le system windows peut être assigné à un groupe de travail (workgroup) ou à un domaine lors de l'installation. Si le system a été assigné à un groupe de travail il gère la base de donnée SAM localement et y stocke tout les utilisateurs existant. Mais si le system a été joint à un domaine, le controlleur de Domaine doit valider les informations d'identification à partir de la base de donnée Active Directory (ntds.dit) qui est stockée dans %SystemRoot%\ntds.dit

NTDS: chaque controller de domain héberge un fichier appellé ntds.dit synchronisé entre tout les controllers de domain à l'exception de ceux en lecture seule (RODC) => serveur Active Directory sécurisé conçu pour les « sites distants physiquement vulnérables. Ce fichier contient sans s'y limiter, Comptes utilisateurs et Hashages de mots de passe. Compte de groupes + Comptes d'ordinateur + Objet de Stratégie de Groupe (GPO).

Credential Manager: ou gestionnaire d'informations d'identification est une fonctionnalité intégrée à tout les systems d'exploitation Windows, qui permet aux utilisateurs de stocker et gerer les informations d'identifications utilisées pour accéder aux ressources réseaux sites web et application. Les infos sont enregistrés et stockés dans le Credentials Locker de l'utilisateur. PS C:\Users\[Username]\AppData\Local\Microsoft\[Vault/Credentials]\ - Vault pour l'identification Web et Credentials pour les informations d'authentification Windows.

Attaques contre SAM, SYSTEM et SECURITY:

- Avec un acces administratif à un system windows on peu tenter de récupérer rapidement les fichiers associés à la base de donnée SAM, les exfiltrer sur notre machine et commencer à cracker les hashages hors lignes.

• Il existe trois ruches du registre que nous pouvons copier avec un acces administrateur au system cible chacune ayant pour nous un objectif spécifique.

HKLM\SAM: Contient les hashages de mots de passe de tout les comptes utilisateurs locaux. Ils peuvent etres extraits et craqués pour révéler les mdp en clair.

HKLM\SYSTEM: Stocke la clé de demarrage du system bootkey qui est utilisée pour